

T.IA — Evidências de conformidade técnica

Primeira entrega do Projeto Integrador (PI)

Sistema de apoio cognitivo gamificado para crianças de 2 a 7 anos com TEA Nível I

Campo	Identificação
Equipe	Natan e Lorena
Artefato	Documentação oficial de conformidade e evidências (Requisitos 1 e 2)
Aplicação local	http://localhost:8080
Caixa de e-mail de teste	Mailpit — http://localhost:8025
Repositório	Código-fonte, este documento e os detalhes em REQUISITO-1-autenticacao.md / REQUISITO-2-recuperacao-senha.md
Data de referência da implementação	29/08/2026

Este texto destina-se à banca avaliadora. Demonstra **domínio da teoria** (criptografia de senhas, segundo fator TOTP, limitação de taxa, gestão de sessão e auditoria alinhada à LGPD) e **rastreabilidade até o código** do monólito.

1. Introdução e arquitetura de infraestrutura

1.1 O produto T.IA e a escolha do canal Web

O T.IA é uma aplicação de apoio cognitivo voltada a crianças com Transtorno do Espectro Autista (TEA) Nível I, na faixa etária de 2 a 7 anos. A primeira entrega do PI **não** implementa ainda os módulos de jogos: o recorte pontuado pela disciplina é a **base de identidade e proteção de contas** dos perfis **Responsável** e **Mediador**, sobre a qual as demais funcionalidades se apoiarão.

A equipe optou por um **monólito Web responsivo** em detrimento de um aplicativo nativo (Android/iOS) nesta etapa, com as seguintes justificativas de engenharia:

1. **Acesso imediato.** Qualquer dispositivo com navegador atualizado (incluindo o telefone do Mediador, usado no fluxo de 2FA) abre http://localhost:8080 sem loja de aplicativos nem processo de sideload.
2. **Eliminação do teto de instalação.** Pacotes nativos frequentemente impõem limite prático da ordem de 450 MB de artefatos no dispositivo do avaliador ou do responsável. A interface Blade + Tailwind é servida

pelo Nginx; o peso da instalação local recai sobre o ambiente Docker da equipe, não sobre o aparelho do usuário final.

3. **Compatibilidade e manutenção única.** Um único código (PHP, Blade, CSS utilitário) atende viewport de desktop e de smartphone (meta viewport, classes sm: / max-w-md, alvos de toque min-h-11). Não há duas codebases (Kotlin/Swift) para a mesma política de senha, lockout e 2FA.
4. **Demonstrabilidade exigida pela disciplina.** Os requisitos devem ser exercitados pelo front-end. HTML servido localmente permite prints em modo dispositivo móvel (DevTools) e inspeção concomitante de MySQL, Mailpit e logs.

A pilha efetiva desta entrega é:

Camada	Tecnologia
Linguagem / runtime	PHP 8.3 (PHP-FPM no container)
Framework	Laravel 13 (requisito laravel/framework: ^13.17) com Laravel Breeze (Blade)
Apresentação	Blade + Tailwind CSS + Vite
Persistência	MySQL 8.4
Identidade extra	Pacote laragear/two-factor (TOTP RFC 6238)
Isolamento	Docker Compose: App (PHP), Nginx, MySQL, Mailpit e Vite

Nota de precisão acadêmica. O enunciado informal às vezes cita “Laravel 11”. O `composer.json` do repositório declara *Laravel 13*, versão com suporte de segurança vigente na data da entrega. Toda evidência de código abaixo refere-se a essa versão.

1.2 Ambiente dockerizado

O arquivo `docker-compose.yml` na raiz descreve um sistema isolado e reproduzível:

Serviço	Container	Função de segurança / operação
php (tia-php)	Imagem construída em <code>docker/php</code>	Executa o Laravel, hash Argon2id, jobs de mail síncronos e <code>php artisan migrate</code>

nginx (tia-nginx)	nginx:1.27-alpine, porta 8080	Termina HTTP; não expõe PHP diretamente
mysql (tia-mysql)	mysql:8.4, porta 3306	Guarda users.password (digest PHC), sessions (payload cifrado), password_reset_tokens (hash do token) e auth_audit_logs
mailpit (tia-mailpit)	axllent/mailpit, UI 8025 / SMTP 1025	Sink de e-mail local: nenhum recorte de recuperação sai para a Internet
vite (tia-vite)	Node 22, porta 5173	Hot Module Replacement dos assets no desenvolvimento

Justificativa do Mailpit. O fluxo de recuperação de senha **exige** evidência de que o link com token chegou a uma caixa de entrada (item 2.1 e evidência funcional pelo front-end). Em produção usar-se-ia SMTP autenticado (SPF/DKIM). No laboratório acadêmico, enviar mensagens reais geraria: (i) risco de vazamento do token para um provedor externo; (ii) dependência de credenciais; (iii) possível classificação como envio não solicitado. O Mailpit escuta SMTP na rede Docker, armazena a mensagem **somente na memória/disco do container** e oferece UI em localhost:8025. O avaliador vê o link completo sem exfiltrar PII.

Subida canônica (README):

```
cp .env.docker.example .env
docker compose build
docker compose up -d
docker compose exec php php artisan migrate
```

A tabela **sessions** só existe após migrate. Sem esse passo, o driver SESSION_DRIVER=database produz HTTP 500 (Table 'tia.sessions' doesn't exist).

NAME	IMAGE	COMMAND	SERVICE	CREATED	STATUS	PORTS
tia-mailpit	axllent/mailpit	"/mailpit"	mailpit	7 minutes ago	Up 7 minutes (healthy)	0.0.0.0:1025->1025/tcp, [::]:1025->1025/tcp, 0.0.0.0:8025->8025/tcp, [::]:8025->8025/tcp, 1110/tcp
tia-mysql	mysql:8.4	"docker-entrypoint.s..."	mysql	7 minutes ago	Up 7 minutes (healthy)	0.0.0.0:3306->3306/tcp, [::]:3306->3306/tcp, 33060/tcp
tia-nginx	nginx:1.27-alpine	"/docker-entrypoint..."	nginx	7 minutes ago	Up 7 minutes	0.0.0.0:8080->80/tcp, [::]:8080->80/tcp
tia-php	tia-php	"docker-php-entrypoi..."	php	7 minutes ago	Up 7 minutes	9000/tcp
tia-vite	node:22-alpine	"docker-entrypoint.s..."	vite	7 minutes ago	Up 7 minutes	0.0.0.0:5173->5173/tcp, [::]:5173->5173/tcp

2. Engenharia de segurança: detalhamento de conformidade

Referências normativas usadas na argumentação: **OWASP Password Storage Cheat Sheet**, **RFC 9106 (Argon2)**, **RFC 6238 (TOTP)**, **LGPD (Lei nº 13.709/2018, princípios da minimização e da segurança)**, e as matrizes dos documentos REQUISITO-1-autenticacao.md e REQUISITO-2-recuperacao-senha.md.

A. Requisito 1 — Autenticação e gestão de credenciais

A.1 Hash criptográfico e salt (itens 1.1, 1.2, 1.3, 1.4)

Teoria. Armazenar senha em claro ou com função rápida (MD5/SHA-1) permite rainbow tables e quebra massiva em GPU. Funções de password hashing modernas são **deliberadamente lentas e consumidoras de memória**, de modo que o custo de testar bilhões de candidatas torne-se inviável. O **Argon2id** (RFC 9106) é a variante híbrida recomendada pelo OWASP para senhas em servidor: combina resistência a ataques de GPU/ASIC (pelo parâmetro de memória) com resistência a ataques de canal lateral (componente data-independent).

O digest no formato PHC (Password Hashing Competition) encapsula, numa única string:

```
$argon2id$v=19$m=65536,t=4,p=1$<salt-em-base64>$<hash-em-base64>
```

Não existe coluna salt. O salt é **gerado aleatoriamente pela biblioteca criptográfica** (password_hash() / libsodium) a **cada** Hash::make(). Dois usuários com a mesma senha produzem strings distintas; uma tabela arco-íris global deixa de aplicar.

Implementação no T.IA.

Decisão	Onde
Driver padrão Argon2id	src/config/hashing.php → 'driver' => env('HASH_DRIVER', 'argon2id')
Custos	ARGON_MEMORY=65536 (64 MiB), ARGON_TIME=4 (passes), ARGON_THREADS=1
Aplicação automática	Cast Eloquent 'password' => 'hashed' em src/app/Models/User.php
Persistência	Coluna users.password (VARCHAR(255)), migration 0001_01_01_000000_create_users_table.php
Rehash futuro	'rehash_on_login' => true — se os custos subirem, o digest atualiza no próximo login válido

O cadastro (RegisteredUserController::store) atribui \$request->password em claro **apenas no request HTTP**. O cast hashed invoca Hash::make() antes do INSERT. A senha **nunca** é logada nem gravada em auth_audit_logs.

Justificativa dos custos (não são “máximo bancário”; são **explícitos e reproduzíveis** para a disciplina): 64 MiB e 4 passes encarecem o ataque paralelo sem tornar o login inutilizável no PHP-FPM do container acadêmico. Um único thread evita saturar o pool FPM sob vários logins simultâneos.

Testes automatizados usam HASH_DRIVER=bcrypt com poucos rounds (phpunit.xml) para a suíte não ficar lenta. **A evidência 1.8 para a banca deve ser o MySQL do Docker**, cujo digest começa com \$argon2id\$.

LGPD. A senha é **dado de autenticação**, não dado cadastral a ser tratado em claro. Minimização: só o digest PHC é persistido; logs usam email_hash (SHA-256), nunca o e-mail em claro.

A.2 Autenticação de dois fatores — 2FA (itens 1.5, 1.6)

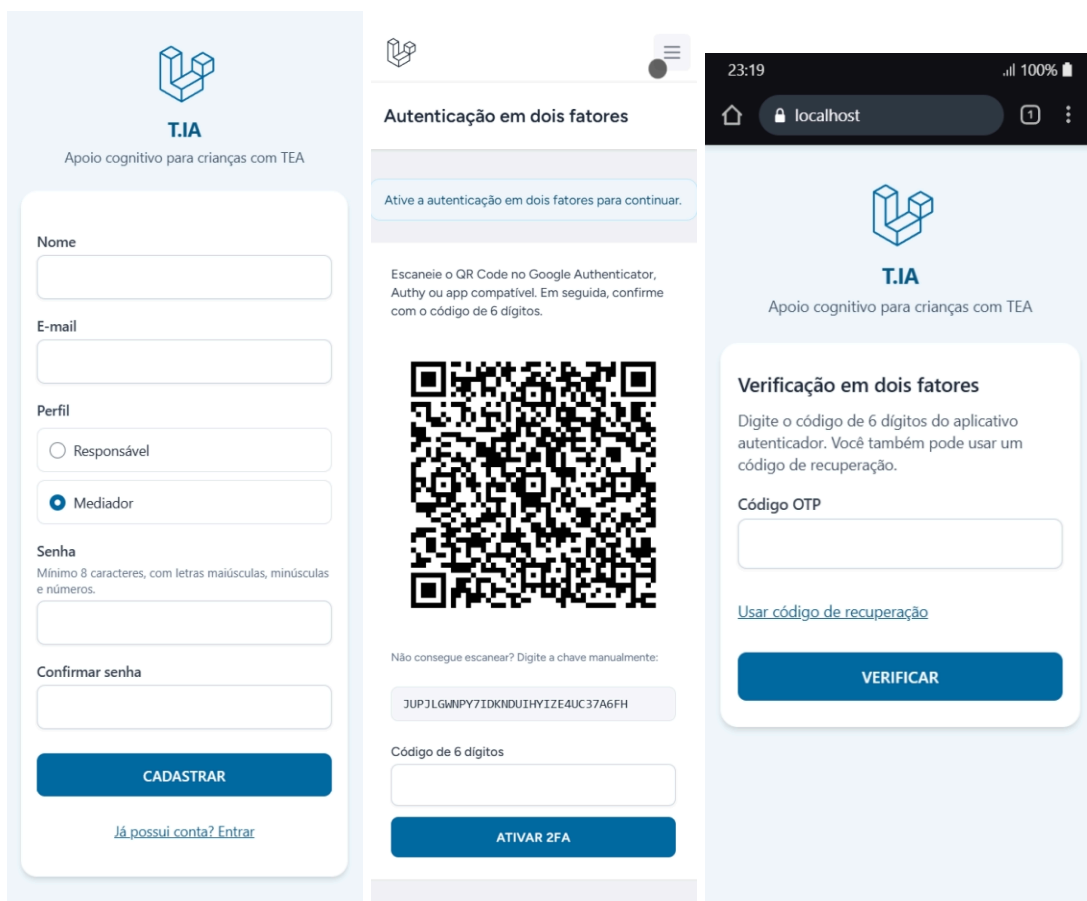
Teoria. O fator “algo que você sabe” (senha) é insuficiente contra phishing e vazamento de hashes. O segundo fator TOTP (RFC 6238) é “algo que você tem”: um segredo compartilhado no autenticador (Google Authenticator, Authy etc.) que gera códigos de **6 dígitos** a cada período de aproximadamente **30 segundos**. O servidor recalcula o OTP com o mesmo segredo e compara de forma timing-safe. Um OTP **não deve ser reutilizável** na mesma janela (o Laragear guarda códigos já usados em cache, prefixo 2fa.code).

Por que não SMS e não Fortify. SMS é interceptável (SIM swap) e caro. O Laravel Fortify entra em conflito com o scaffold Breeze já adotado. O pacote **laragear/two-factor (^4.0)** integra-se ao model User via trait TwoFactorAuthentication.

Fluxo de ativação (Mediador).

5. Cadastro em POST /register com role=mediador (RegisteredUserController). Política de senha: Password::min(8)->mixedCase()->numbers() (AppServiceProvider).
6. Login primário (e-mail + senha). Sem 2FA confirmado, o middleware mediator.2fa (App\Http\EnsureMediatorTwoFactor, alias em bootstrap/app.php) bloqueia o painel e redireciona para GET /user/two-factor.
7. TwoFactorController::show chama \$user->createTwoFactorAuth() e envia à view o QR em SVG (toQr()) e, opcionalmente, a chave manual. O segredo TOTP permanece cifrado na tabela two_factor_authentications, não em cookie.
8. TwoFactorController::confirm exige code com digits:6. Só confirmTwoFactorAuth() marca o 2FA como enabled. Códigos de recuperação são exibidos uma vez (flash de sessão).
9. Mediador não pode DELETE o 2FA (abort(403)). Safe devices está desligado (config/two-factor.php): todo login subsequente pede OTP.

Fluxo de desafio pós-senha (item 1.6). LoginRequest::authenticate() usa Auth2FA::attempt(). Se a senha está correta e o 2FA está ativo, o pacote **não abre a sessão**: devolve o desafio (tela auth/two-factor-challenge.blade.php). Somente o OTP (ou recovery code) válido completa Auth::login. OTP inválido incrementa a chave login-2fa:{ip} no mesmo teto de 5 tentativas / 2 horas.



A.3 Sessões e logout (itens 1.9, 1.10)

Teoria. Sessão apenas em cookie opaco dificulta **invalidação global** (roubo de cookie, troca de senha). Persistência em banco permite DELETE FROM sessions WHERE user_id = ?. Cifrar o payload (SESSION_ENCRYPT=true) reduz o impacto de um dump da tabela. Expiração por **inatividade** (idle) limita a janela de uma sessão abandonada no laboratório da clínica/escola.

Configuração T.I.A (src/config/session.php e .env):

Parâmetro	Valor	Efeito
SESSION_DRIVER	database	Linhas na tabela sessions
SESSION_LIFETIME	120 minutos	Idle de duas horas
SESSION_ENCRYPT	true	Payload cifrado em repouso

Login. Após autenticação bem-sucedida, `AuthenticatedSessionController::store` chama `$request->session()->regenerate()` — mitiga **session fixation**.

Logout (destroy). Ordem deliberada:

10. `Auth::guard('web')->logout()`
11. `DB::table('sessions')->where('user_id', $userId)->delete()` — encerra todas as sessões daquele usuário (outros navegadores)
12. `invalidate()` + `regenerateToken()` (CSRF)

A redefinição de senha (Requisito 2) executa o mesmo DELETE sobre `user_id`, para um token de reset roubado não manter um invasor autenticado.

```
mysql> SELECT id, LEFT(password, 24) FROM users;
+----+-----+
| id | LEFT(password, 24) |
+----+-----+
| 1  | $argon2id$v=19$m=65536,t=1 |
+----+-----+
1 row in set (0.00 sec)

mysql>
mysql> SELECT * FROM sessions WHERE user_id = 1;
+----+-----+-----+-----+-----+
| id | user_id | ip_address | user_agent | payload |
+----+-----+-----+-----+-----+
| 1  | 1       | 172.18.0.1 | Mozilla/5.0 (iPhone; CPU iPhone OS 26_0_1 like Mac OS X) AppleWebKit/605.1.15 (KHTML, like Gecko) Version/26.0.1 Mobile/15E148 Safari/604.1 | 2XlCcRps7ZJng4WkVcQTRlPUEZ6WQWdGcFtRz16VWFO8TSM |
+----+-----+-----+-----+-----+
1 row in set (0.00 sec)
```

A.4 Proteção contra força bruta — lockout de 2 horas (item 1.11)

Teoria. Sem teto, um atacante testa milhares de senhas por minuto. O rate limit do Breeze padrão (decaimento curto, da ordem de um minuto) **não atende** o enunciado acadêmico (5 falhas → **2 horas**).

Limitação **só por IP** é contornada com botnets; **só por e-mail** é contornada trocando o endereço de origem. A defesa correta neste PI é **conjunção**: qualquer eixo no limite bloqueia.

Implementação. Não se trata apenas do middleware `throttle:login`. Há **duas camadas**:

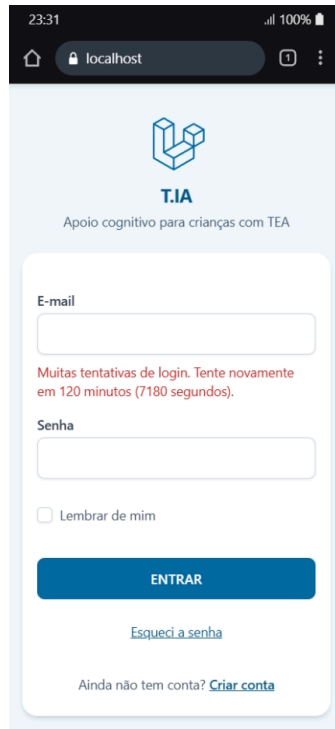
13. **Anti-inundação HTTP (AppServiceProvider):** `RateLimiter::for('login')` → 20 POSTs por minuto por IP, aplicado na rota `POST /login` (`routes/auth.php`). Impede flood de requisições, independentemente de a senha estar certa ou errada.
14. **Lockout acadêmico (LoginRequest::ensureIsNotRateLimited e RateLimiter::hit após falha):**

Chave	Formato	Quando incrementa
E-mail	login-email:{email-normalizado}	Senha primária inválida
IP	login-ip:{ip}	Senha primária inválida
OTP	login-2fa:{ip}	Código 2FA / recovery inválido

- Teto: LOGIN_MAX_ATTEMPTS=5
- Janela: LOGIN_DECAY_SECONDS=7200 (2 horas)
- Na 6ª tentativa, dispara-se o evento Lockout (listener AuditAuthLockout grava login_lockout, meta.minutes = 120) e a validação lança mensagem auth.throttle com minutos restantes (ceil(\$seconds / 60), tipicamente 120 minutos) e segundos.

Login (e OTP) **correto** executa RateLimiter::clear nas três chaves.

A view login.blade.php (e o desafio 2FA) exhibe o erro em errors.email, em layout responsivo (guest.blade.php, max-w-md, px-4).



B. Requisito 2 — Recuperação de senha

B.1 Fluxo geral e tokens seguros (itens 2.1, 2.2, 2.3, 2.4, 2.5)

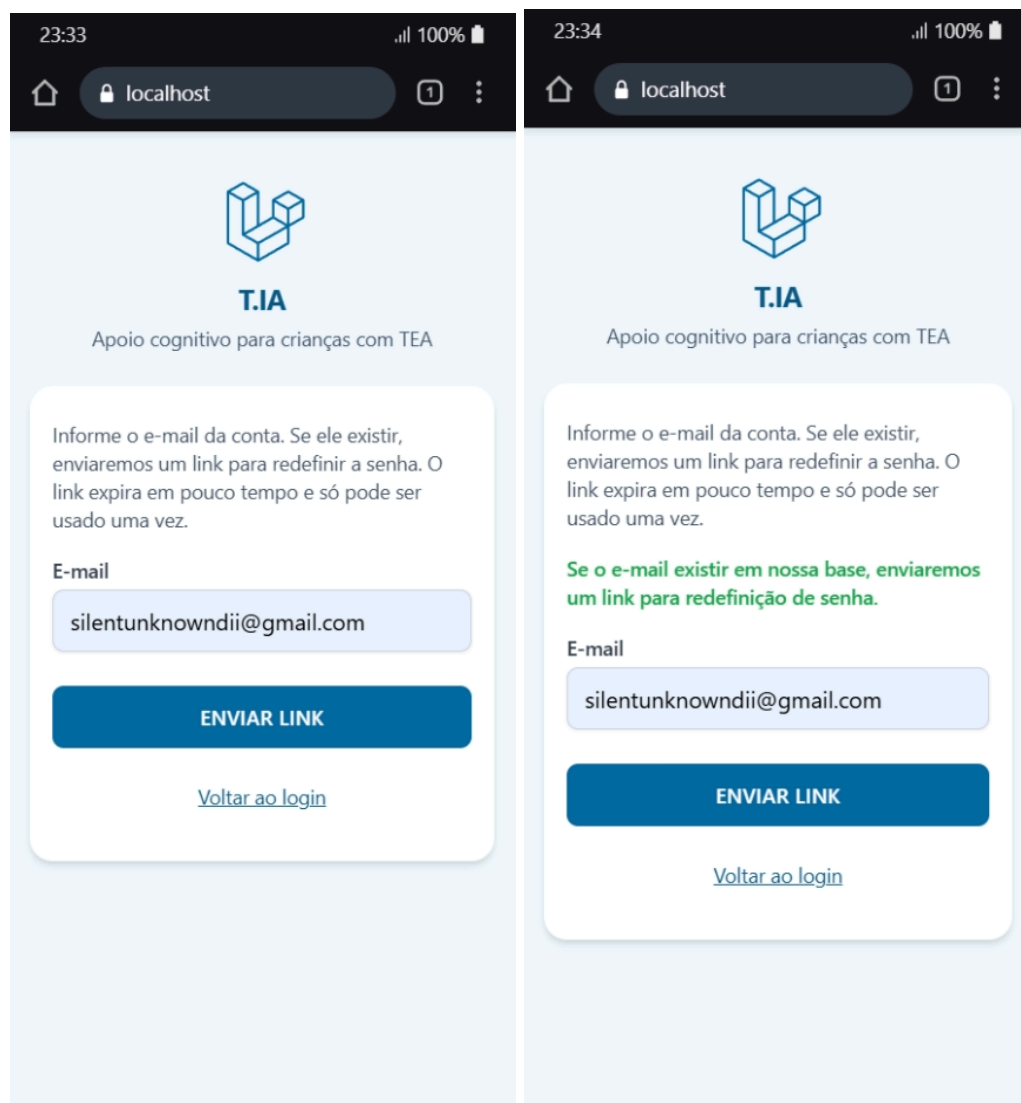
Teoria do token. Um link “esqueci a senha” é um **segredo de curta duração**. Se o valor persistido no banco for igual ao da URL, um SQL dump permite redefinir qualquer conta. Por isso o Laravel:

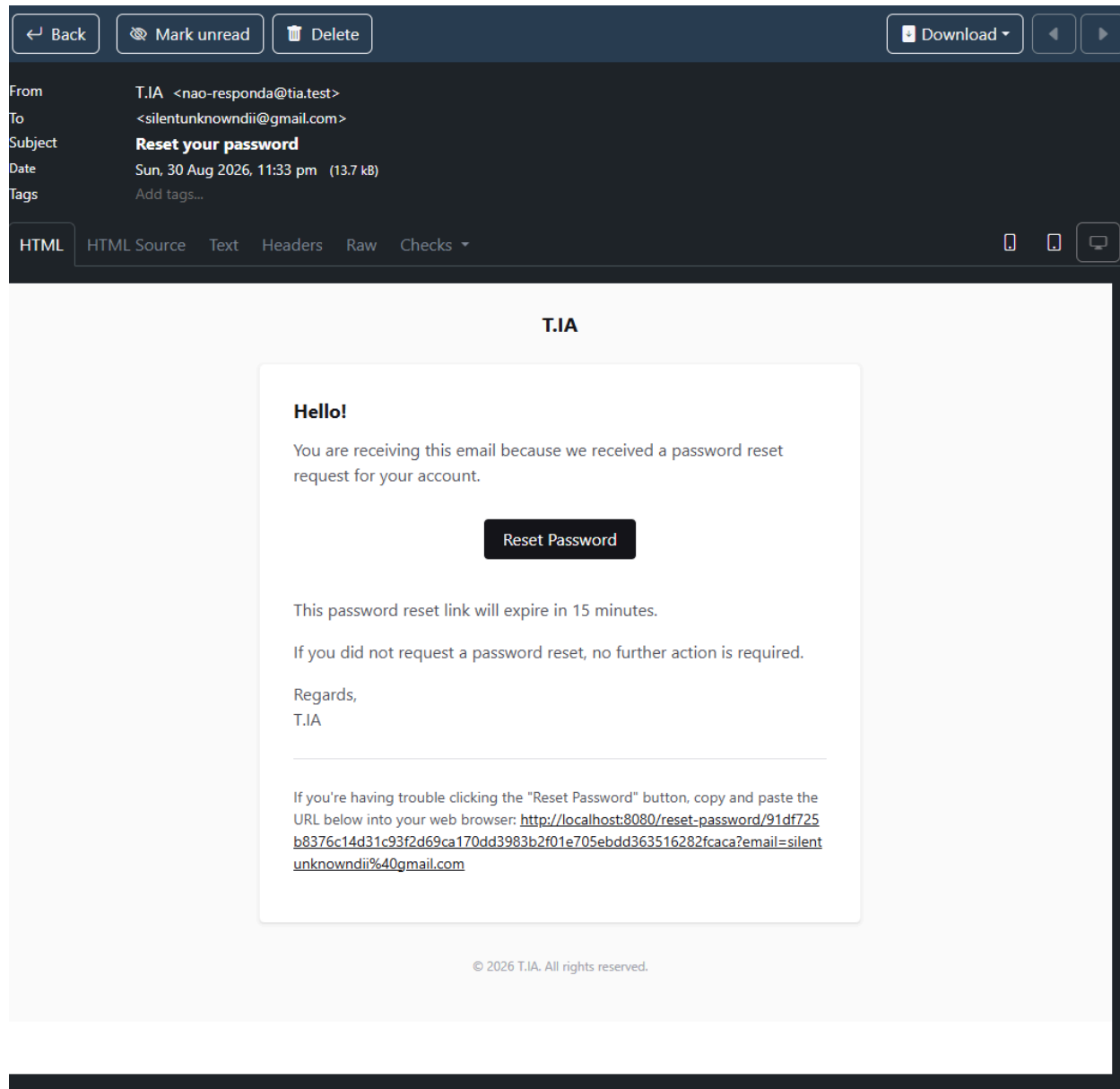
15. **Gera** o token com `hash_hmac('sha256', Str::random(40), $hashKey)` em `Illuminate\Auth\Passwords\DatabaseTokenRepository::createNewToken()`. O HMAC-SHA256, chaveado com `APP_KEY`, produz 256 bits de saída a partir de 40 caracteres aleatórios — o atacante não prevê o link mesmo conhecendo o algoritmo.
16. **Persiste** apenas `$this->hasher->make($token)` (no T.IA, Argon2id) na coluna `password_reset_tokens.token`. O e-mail transporta o HMAC em claro; o MySQL não.
17. **Confere** com `$this->hasher->check($token, $record['token'])` (comparação timing-safe do hasher).
18. **Expira** pelo `created_at + PASSWORD_RESET_EXPIRE` (15 minutos em `config/auth.php`).

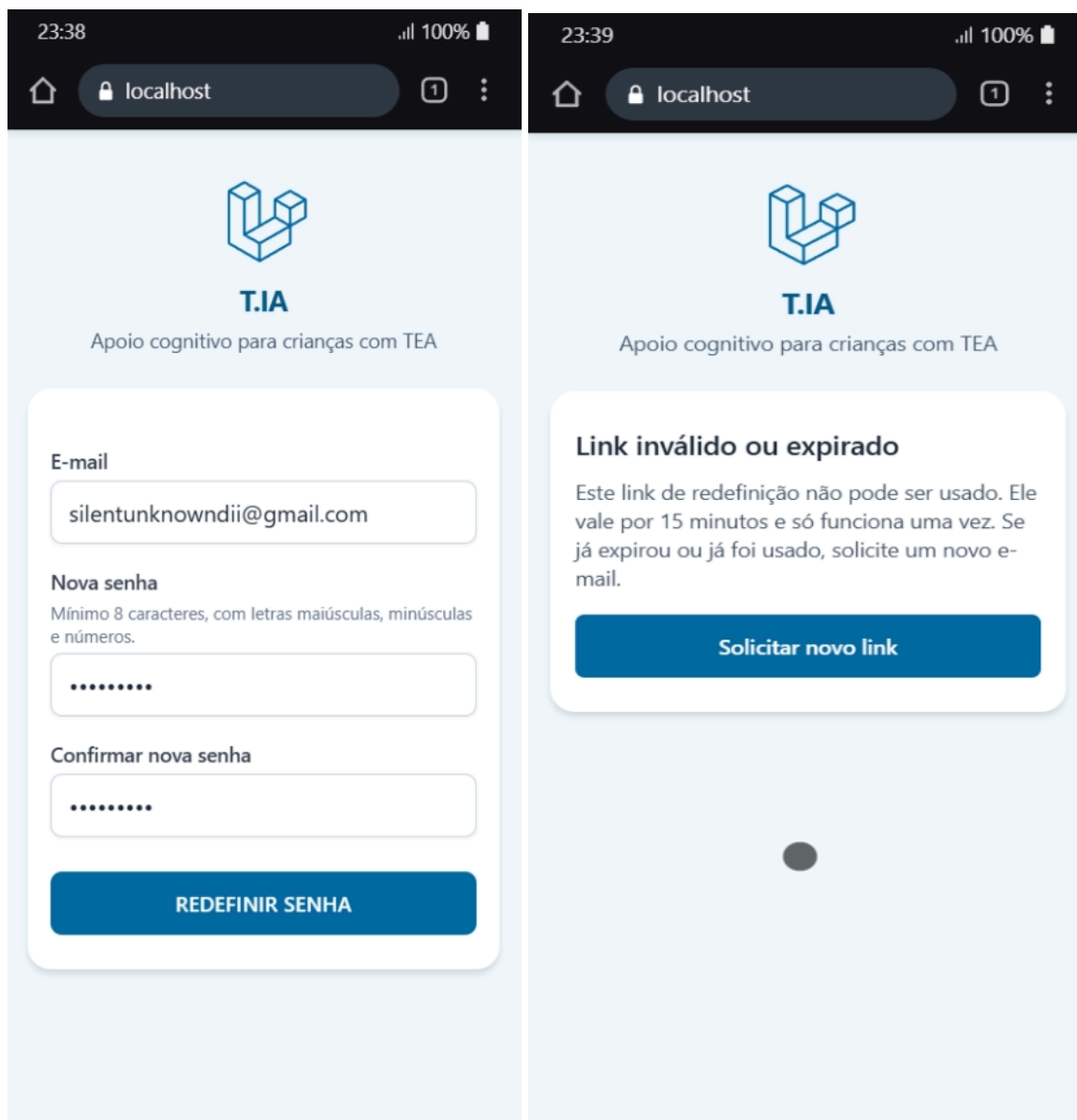
19. **Destrói** a linha no sucesso (deleteExisting / delete do broker) — uso único, bloqueio de replay. Há ainda auth:clear-resets agendado a cada 15 minutos (routes/console.php) para resíduos expirados.
20. **Anti-enumeração:** PasswordResetLinkController::store devolve sempre a mensagem genérica RESET_LINK_SENT, exista ou não a conta. Falhas (unknown_user, throttled 60 s) vão só para a auditoria.

Controladores T.IA.

- Pedido: PasswordResetLinkController — Password::sendResetLink().
- Consumo: NewPasswordController::create valida o token já no GET. Link morto → reset-password-invalid.blade.php sem campos de senha (item 2.5).
- store chama Password::reset(); sucesso regrava senha (cast hashed / Argon2id), rotaciona remember_token, DELETE FROM sessions WHERE user_id = ?, dispara PasswordReset.
- Falha: AuditAuthEvent com outcome=failure e meta.reason=invalid_or_expired_token.







B.2 Logs de auditoria e conformidade LGPD (itens 2.6, 2.7)

Teoria. Auditoria de segurança precisa ser **imputável** (quem/quando/de onde) sem transformar o arquivo de log num segundo cadastro de PII. A LGPD exige base legal, minimização e segurança. E-mail em claro no storage/logs seria dado pessoal exposto a quem lê o disco do container.

Implementação. A classe `App\Actions\AuditAuthEvent` é o ponto único de gravação:

Campo JSON	Origem	Observação LGPD / forense
timestamp	<code>now()->toIso8601String()</code>	Ordenação temporal

event / outcome	Parâmetros do listener	Taxonomia estável
email_hash	hash('sha256', strtolower(trim(\$email)))	Correlação sem e-mail em claro
ip	request()->ip()	Indicador de origem (dado de conexão)
user_agent	request()->userAgent()	Contexto do cliente
meta	Motivos técnicos (reason, source, minutes)	Sem senha, OTP ou token

Destinos duplos (disponibilidade da evidência):

21. **Canal Monolog audit (config/logging.php):** driver daily, arquivo storage/logs/audit-YYYY-MM-DD.log (o path configurado é audit.log; o Laravel sufixa a data). Cada linha é um objeto JSON. O enunciado cita audit.json; o conteúdo é JSON estruturado — o print deve mostrar essas linhas.
22. **Tabela auth_audit_logs (migration 2026_08_29_230100_create_auth_audit_logs_table.php):** Falha no MySQL não derruba o fluxo de autenticação (catch em AuditAuthEvent).

Listeners (descoberta automática do Laravel):

Classe	Evento de framework	Registro
AuditPasswordResetLinkSent	PasswordResetLinkSent	password_reset_link_sent / success
AuditPasswordResetSucceeded	PasswordReset	password_reset / success
Falha no controller	—	password_reset / failure (invalid_or_expired_token, link_opened)
AuditLoginFailed	Failed	login_failed
AuditAuthLockout	Lockout	login_lockout
AuditTwoFactorEnabled	TwoFactorEnabled (Laragear)	two_factor_enabled

O item **2.7** (invalidação de sessão após troca) está no callback de Password::reset em NewPasswordController, complementar à auditoria.

```
src/storage/logs/audit-2026-08-29.log [2026-08-29 23:16:10] testing.INFO: {"timestamp":"2026-08-29T23:16:10+00:00","event":"password_reset_link_sent","outcome":"success","email_hash":"ddfbfb58bc9fca679453f87594f02ac3729022a0f4e40e659330f5ee7baa309","ip":"127.0.0.1","user_agent":"Symfony","meta":[]}
src/storage/logs/audit-2026-08-29.log [2026-08-29 23:16:10] testing.INFO: {"timestamp":"2026-08-29T23:16:10+00:00","event":"password_reset","outcome":"success","email_hash":"ddfbfb58bc9fca679453f87594f02ac3729022a0f4e40e659330f5ee7baa309","ip":"127.0.0.1","user_agent":"Symfony","meta":[]}
src/storage/logs/audit-2026-08-29.log [2026-08-29 23:16:10] testing.INFO: {"timestamp":"2026-08-29T23:16:10+00:00","event":"password_reset","outcome":"failure","email_hash":"ddfbfb58bc9fca679453f87594f02ac3729022a0f4e40e659330f5ee7baa309","ip":"127.0.0.1","user_agent":"Symfony","meta":{"reason":"invalid_or_expired_token","source":"link_opened"}}
src/storage/logs/audit-2026-08-29.log [2026-08-29 23:16:10] testing.INFO: {"timestamp":"2026-08-29T23:16:10+00:00","event":"password_reset_link_sent","outcome":"success","email_hash":"47761944010b66ed9ddd82914979b74c4f40951e54a22cca0f4025ee97150a","ip":"127.0.0.1","user_agent":"Symfony","meta":[]}
src/storage/logs/audit-2026-08-29.log [2026-08-29 23:16:10] testing.INFO: {"timestamp":"2026-08-29T23:16:10+00:00","event":"password_reset","outcome":"success","email_hash":"47761944010b66ed9ddd82914979b74c4f40951e54a22cca0f4025ee97150a","ip":"127.0.0.1","user_agent":"Symfony","meta":[]}
src/storage/logs/audit-2026-08-29.log [2026-08-29 23:16:10] testing.INFO: {"timestamp":"2026-08-29T23:16:10+00:00","event":"password_reset_link_sent","outcome":"success","email_hash":"cc5353d35b3809885efe4092c41db1cb3468039c2a639e20f280cac768a65b66","ip":"127.0.0.1","user_agent":"Symfony","meta":[]}
src/storage/logs/audit-2026-08-29.log [2026-08-29 23:16:10] testing.INFO: {"timestamp":"2026-08-29T23:16:10+00:00","event":"password_reset","outcome":"success","email_hash":"cc5353d35b3809885efe4092c41db1cb3468039c2a639e20f280cac768a65b66","ip":"127.0.0.1","user_agent":"Symfony","meta":{"reason":"invalid_or_expired_token"}}
src/storage/logs/audit-2026-08-29.log [2026-08-29 23:16:10] testing.INFO: {"timestamp":"2026-08-29T23:16:10+00:00","event":"password_reset_link_sent","outcome":"success","email_hash":"71101fcb02bd7dd80cf2e6004b2afe2cfc03990b21e1aa0d314f4f01dee6d98","ip":"127.0.0.1","user_agent":"Symfony","meta":[]}
src/storage/logs/audit-2026-08-29.log [2026-08-29 23:16:11] testing.INFO: {"timestamp":"2026-08-29T23:16:11+00:00","event":"password_reset","outcome":"failure","email_hash":"71101fcb02bd7dd80cf2e6004b2afe2cfc03990b21e1aa0d314f4f01dee6d98","ip":"127.0.0.1","user_agent":"Symfony","meta":{"reason":"invalid_or_expired_token"}}
src/storage/logs/audit-2026-08-29.log [2026-08-29 23:16:11] testing.INFO: {"timestamp":"2026-08-29T23:16:11+00:00","event":"password_reset_link_sent","outcome":"success","email_hash":"bc126c3d9591b9e7c9f9addf9194a4f48f1de9e5779eb2bc18c61a76b16bd95","ip":"127.0.0.1","user_agent":"Symfony","meta":[]}
src/storage/logs/audit-2026-08-29.log [2026-08-29 23:16:11] testing.INFO: {"timestamp":"2026-08-29T23:16:11+00:00","event":"password_reset","outcome":"success","email_hash":"bc126c3d9591b9e7c9f9addf9194a4f48f1de9e5779eb2bc18c61a76b16bd95","ip":"127.0.0.1","user_agent":"Symfony","meta":[]}
src/storage/logs/audit-2026-08-29.log [2026-08-29 23:16:11] testing.INFO: {"timestamp":"2026-08-29T23:16:11+00:00","event":"password_reset","outcome":"success","email_hash":"530de44232bce08dcd37a33d54cc6b1684d580669e340ab352338de088925a","ip":"127.0.0.1","user_agent":"Symfony","meta":[]}
src/storage/logs/audit-2026-08-29.log [2026-08-29 23:16:11] testing.INFO: {"timestamp":"2026-08-29T23:16:11+00:00","event":"password_reset","outcome":"failure","email_hash":"f0adc116e8b4632873747d64dd4dd685a4095b0685a4095b0685a28e11c8759b2951a939c2ab","ip":"172.18.0.1","user_agent":"Mozilla/5.0 (iPhone; CPU iPhone OS 26_0_1 like Mac OS X) AppleWebKit/605.1.15 (KHTML, like Gecko) Version/26.0 Mobile/15E148 Safari/604.1","meta":[]}
src/storage/logs/audit-2026-08-31.log [2026-08-31 02:39:08] local.INFO: {"timestamp":"2026-08-31T02:39:08+00:00","event":"password_reset","outcome":"success","email_hash":"f0adc116e8b4632873747d64dd4dd685a4095b0685a28e11c8759b2951a939c2ab","ip":"172.18.0.1","user_agent":"Mozilla/5.0 (iPhone; CPU iPhone OS 26_0_1 like Mac OS X) AppleWebKit/605.1.15 (KHTML, like Gecko) Version/26.0 Mobile/15E148 Safari/604.1","meta":[]}
src/storage/logs/audit-2026-08-31.log [2026-08-31 02:39:11] local.INFO: {"timestamp":"2026-08-31T02:39:11+00:00","event":"password_reset","outcome":"failure","email_hash":"f0adc116e8b4632873747d64dd4dd685a4095b0685a28e11c8759b2951a939c2ab","ip":"172.18.0.1","user_agent":"Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36","meta":{"reason":"invalid_or_expired_token","source":"link_opened"}}
src/storage/logs/audit-2026-08-31.log [2026-08-31 02:39:17] local.INFO: {"timestamp":"2026-08-31T02:39:17+00:00","event":"password_reset","outcome":"failure","email_hash":"f0adc116e8b4632873747d64dd4dd685a4095b0685a28e11c8759b2951a939c2ab","ip":"172.18.0.1","user_agent":"Mozilla/5.0 (iPhone; CPU iPhone OS 26_0_1 like Mac OS X) AppleWebKit/605.1.15 (KHTML, like Gecko) Version/26.0 Mobile/15E148 Safari/604.1","meta":{"reason":"invalid_or_expired_token","source":"link_opened"}}
src/storage/logs/audit-2026-08-31.log [2026-08-31 02:39:17] local.INFO: {"timestamp":"2026-08-31T02:39:17+00:00","event":"password_reset","outcome":"failure","email_hash":"f0adc116e8b4632873747d64dd4dd685a4095b0685a28e11c8759b2951a939c2ab","ip":"172.18.0.1","user_agent":"Mozilla/5.0 (iPhone; CPU iPhone OS 26_0_1 like Mac OS X) AppleWebKit/605.1.15 (KHTML, like Gecko) Version/26.0 Mobile/15E148 Safari/604.1","meta":{"reason":"invalid_or_expired_token","source":"link_opened"}}
src/storage/logs/audit-2026-08-31.log [2026-08-31 02:39:24] local.INFO: {"timestamp":"2026-08-31T02:39:24+00:00","event":"password_reset","outcome":"failure","email_hash":"f0adc116e8b4632873747d64dd4dd685a4095b0685a28e11c8759b2951a939c2ab","ip":"172.18.0.1","user_agent":"Mozilla/5.0 (iPhone; CPU iPhone OS 26_0_1 like Mac OS X) AppleWebKit/605.1.15 (KHTML, like Gecko) Version/26.0 Mobile/15E148 Safari/604.1","meta":{"reason":"invalid_or_expired_token","source":"link_opened"}}
```

3. Processo de desenvolvimento (Kanban)

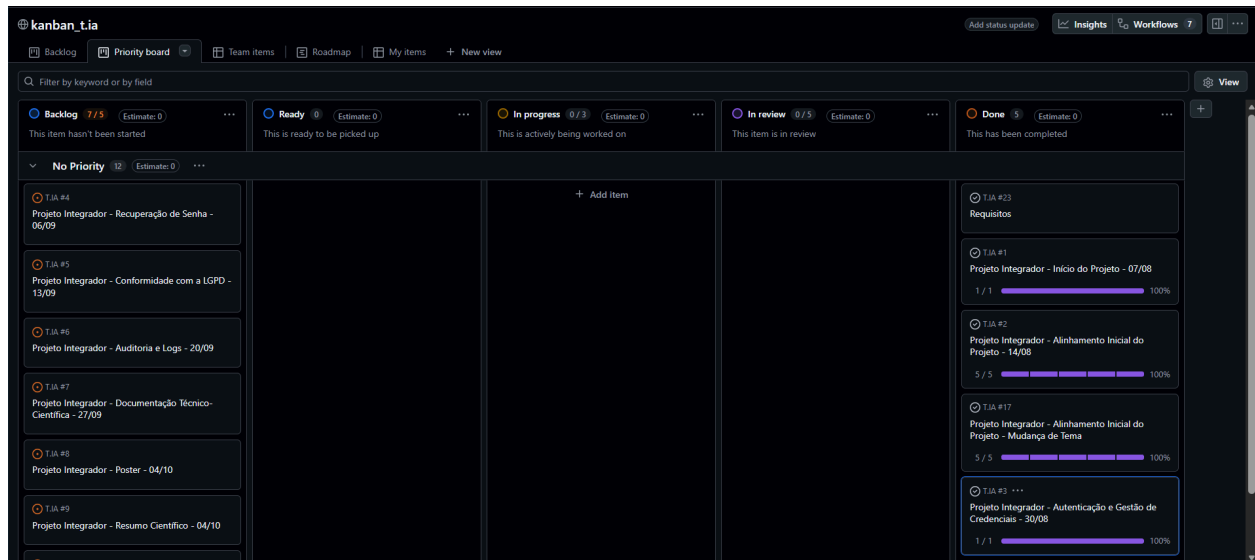
A dupla **Natan** e **Lorena** conduziu esta entrega sob um quadro **Kanban** (visualização contínua do fluxo), com cadência próxima ao **Scrum** de PI (incrementos inspecionáveis: ambiente, identidade, segundo fator, recuperação, evidências).

Colunas mínimas exigidas pela disciplina:

Coluna	Significado nesta entrega
To Do	Itens ainda não iniciados (ex.: prints 1.8/2.9, release v1.0.0-PI, conversão Markdown → PDF)
In Progress	Trabalho ativo da dupla (Docker, Argon2id/lockout, 2FA Laragear, Mailpit/reset, auditoria JSON)
Done	Critério de pronto: código na branch, teste Pest correspondente e/ou evidência de front-end

A divisão de responsabilidade típica de um PI em dupla — **infraestrutura e operação** (Compose, Nginx, MySQL, Mailpit, migrate) versus **domínio de segurança e UX** (Breeze, views responsivas, 2FA, lockout, listeners) — permanece visível no quadro ao longo das semanas, o que atende à exigência de processo e reduz a percepção de entrega monolítica sem rastreio.

O histórico Git (feature/docker-auth-2fa-recovery-logs) complementa o Kanban, mas **não o substitui**: a disciplina prevê penalidade na ausência do painel.



4. Mapa rápido de rastreabilidade (código)

Exigência	Artefato principal
1.1–1.4 Argon2id + salt	config/hashing.php, User (cast hashed), RegisteredUserController
1.5–1.6 2FA TOTP	laragear/two-factor, TwoFactorController, EnsureMediatorTwoFactor, LoginRequest + Auth2FA::attempt()
1.9–1.10 Sessão / logout	config/session.php, AuthenticatedSessionController::destroy
1.11 Lockout 5 × 2 h	LoginRequest (LOGIN_MAX_ATTEMPTS, LOGIN_DECAY_SECONDS), throttle:login
2.1–2.5 Reset	PasswordResetLinkController, NewPasswordController, DatabaseTokenRepository (HMAC-SHA256 + Hash::make)
2.6–2.7 Auditoria e sessões no reset	AuditAuthEvent, app/Listeners/*, DELETE em sessions

Testes automatizados (não substituem os prints): tests/Feature/Auth/AuthenticationTest.php, TwoFactorAuthenticationTest.php, PasswordResetTest.php.

5. Instruções à equipe para fechar a evidência visual

23. Subir o Compose e rodar `php artisan migrate`.
24. No navegador, ativar o modo dispositivo móvel para as Imagens 2, 3, 4, 6, 7, 8 e 9.
25. Colar as capturas no lugar de cada marcador [Imagem N: ...] (ou em anexo numerado no PDF).
26. Converter este Markdown para PDF juntamente com os requisitos 1 e 2, se a disciplina exigir um único dossiê.

*Documento elaborado para a primeira entrega do PI T.IA. Qualquer divergência entre este texto e o repositório deve ser resolvida **a favor do código versionado** na release oficial do GitHub.*